Project: PyPI Supply Chain Detection Analysis

Author: Alexander Máni Einarsson

Supervisor: Dr. Jacky Mallett

Project Mangement

The project is divided into 4 Phases. Each Phase is divided into 4 Tasksets. Additonally, each taskset will include a minimum of two hours of thesis work.

Phase I: Research, design and setup

~80 Houres

Taskset Ia: Project Organization, Proposal and Orentation

~25 Hours

1. January 12, 2026 - January 18, 2026

2. January 19, 2026 - January 25, 2026

Taskset Ib

1. January 26, 2026 - February 1, 2026

Taskset Ic

1. February 2, 2026 - February 8, 2026

Taskset Id

1. February 9, 2026 - February 15, 2026: **1st Sitrep Meeting**

Phase II: Development of PyPI simulator and diffing engine.

~100 Houres

Taskset IIa

1. February 16, 2026 - February 22, 2026

Taskset IIb

1. February 23, 2026 - March 1, 2026

Taskset IIc

1. March 2, 2026 - March 8, 2026

Taskset IId

1. March 9, 2026 - March 15, 2026: **2nd Sitrep Meeting**

Phase III: Benchmarking Intergration of industry standard SAST and experimental AI analysis tools

~100 Houres

Taskset IIIa

1. March 16, 2026 - March 22, 2026

Taskset IIIb

1. March 23, 2026 - March 29, 2026

Taskset IIIc

1. March 30, 2026 - April 5, 2026

Taskset IIId

1. April 6, 2026 - April 12, 2026
2. April 13, 2026 - April 19, 2026: **TEST PERIOD**
3. April 20, 2026 - April 26, 2026: **TEST PERIOD**

Phase IV: Testing, data collection, and final thesis writing

~100 Houres

Taskset IVa

1. April 27, 2026 - May 3, 2026: **3rd Sitrep Meeting**, **Three Week Starts**

Taskset IVb

1. May 4, 2026 - May 10, 2026

Taskset IVc

1. May 11, 2026 - May 17, 2026

Taskset IVd

1. May 18, 2026 - May 24, 2026: **Presentation of Final Project**

Reading List

PyPitfall (A PyPI supply chain awareness tool) - **Link:** PyPitfall: Dependency Chaos and Software Supply Chain Vulnerabilities in Python - **Date:** 24 Jul 2025 **Author/s:** Jacob Mahon, Chenxi Hou, Zhihao Yao **Published At:** [UNKNOWN]

Source code analyst to Identify supply chain attacks - **Link:** Towards Using Source Code Repositories to Identify Software Supply Chain Attacks - **Date:** 30 October 2020 **Author/s:** Duc Ly Vu, Ivan Pashchenko, Fabio Massacci, Henrik Plate, Antonino Sabetta **Published At:** University of Trento

Supply Chain Attacks: A Comprehensive Analysis of NPM, PyPI, and Docker Hub Vulnerabilities - **Link:** Supply Chain Attacks Through Open Source Software: A Comprehensive Analysis of NPM, PyPI, and Docker Hub Vulnerabilities - **Date:** 12-3-2025 (Under Fall 2025 and other verbose date points to December) **Author/s:** Thomas Pham **Published At:** Old Dominion Published At

Review of Open Source Software Supply Chain Attacks - **Link:** Backstabber's Knife Collection: A Review of Open Source Software Supply Chain Attacks - **Date:** 07 July 2020 **Author/s:** Marc Ohm, Henrik Plate, Arnold Sykosch & Michael Meier **Published At:** Conference paper (DIMVA 2020)

Robust Detection of Open Source Software Supply Chain Poisoning Attacks in Industry - **Link:** Towards Robust Detection of Open Source Software Supply Chain Poisoning Attacks in Industry Environments - **Date:** 27 October 2024 **Author/s:** Xinyi Zheng, Chen Wei, Shenao Wang, Yanjie Zhao, Peiming Gao, Yuanchao Zhang, Kailong Wang, Haoyu WangAuthor/ss Info & Claims **Published At:** Huazhong Published At of Science and Technology, Wuhan, Hubei, China

Extended Reading List

Characterizing Deep Learning Package Supply Chains in PyPI - **Link:** Characterizing Deep Learning Package Supply Chains in PyPI: Domains, Clusters, and Disengagement - **Date:** 18 April 2024 **Author/s:** Kai Gao, Runzhi He, Bing Xie, Minghui Zhou **Published At:** Peking Published At, Bejing, China